

Trabajo Práctico Integrador

Introducción a la Ciberseguridad

Parte 1 - Hardening utilizando Lynis a nivel de sistema operativo

Ejecución de Lynis en maquina local (Kali)

¿Qué Hardening index obtuvo?	61
¿Cuántos warnings?	5
¿Cuántas sugerencias?	66

(adjunto archivo: lynis-resultado-local.txt)

Ejecución de Lynis en “maquina virtual” provista

¿Qué Hardening index obtuvo?	51
¿Cuántos warnings?	6
¿Cuántas sugerencias?	58

(adjunto archivo: salida-lynis pre.txt)

En esta parte se aborda de primera mano los warnings y sugerencias detectados por Lynis. Cada punto describe el hallazgo, su explicación y las acciones aplicadas para corregirlo.

1. Múltiples usuarios con UID 0

Para saber que usuarios que usuarios tienen UID 0 ejecutamos el siguiente comando:

- `awk -F: '($3 == 0) {print $1}' /etc/passwd`

El resultado muestra que existen dos usuarios con UID 0: root y admin2.

Cuando dos usuarios comparten el mismo UID (0), el kernel los considera idénticos en cuanto a privilegios; por lo tanto, cualquier proceso que pertenezca a admin2 tiene los mismos permisos que root.

Modificar el UID o eliminar esta cuenta “en caliente” podría provocar el cierre de la sesión activa o la corrupción de procesos críticos del sistema.

Por ello, se decidió bloquear el acceso de admin2 sin alterar su UID, mediante los siguientes comandos:

- `passwd -l admin2` # Bloquea el inicio de sesión
- `passwd -S admin2` # Verifica el estado de la cuenta
- `usermod -s /usr/sbin/nologin admin2` # Evita el acceso a un shell interactivo

```

root@linux-target:/# passwd -l admin2
passwd: password expiry information changed.
root@linux-target:/# passwd -S admin2
admin2 L 10/31/2025 0 99999 7 -1
root@linux-target:/# usermod -s /usr/sbin/nologin admin2
root@linux-target:/# █

```

[+] Users, Groups and Authentication

- Administrator accounts [WARNING]
- Unique UIDs [WARNING]
- Consistency of group files (group) [OK]

2. Iptables cargado pero sin reglas activas

Este warning indica que el kernel tiene módulos de firewall cargados, pero no hay reglas activas, lo que el sistema no esta filtrando trafico.

Primero vamos a verificar las reglas actuales con el siguiente comando:

- `iptables -S`

En la captura podemos ver que el firewall esta activado pero no esta protegiendo activamente nada.

Probaremos los siguientes comandos para establecer mejores políticas:

- `iptables -P INPUT DROP`
- `iptables -P FORWARD DROP`
- `iptables -A INPUT -i lo -j ACCEPT`
- `iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT`
- `iptables -A INPUT -p tcp --dport 22 -j ACCEPT`
- `iptables -A INPUT -p tcp --dport 80 -j ACCEPT`
- `iptables -A INPUT -p tcp --dport 443 -j ACCEPT`

Esta solución permite eliminar el warning de empty ruleset

[+] Software: firewalls

- Checking iptables support [FOUND]
- Checking iptables policies of chains [FOUND]
 - Chain INPUT (table: filter, target: ACCEPT) [ACCEPT]
 - Chain INPUT (table: filter, target: DROP) [DROP]
 - Chain INPUT (table: security, target: ACCEPT) [ACCEPT]
- Checking for empty ruleset [OK]
- Checking for unused rules [FOUND]
- Checking host based firewall [ACTIVE]

3. Redis world-readable

Este warning, si bien no aparece explícitamente como Warning en el resumen, se genera cuando Lynis verifica los permisos del archivo `/etc/redis/redis.conf` en los test de la base de datos, indica que el archivo `redis.conf` puede ser leído por cualquier usuario. Esto puede revelar contraseñas o puertos sensibles.

Para solucionar esto vamos a probar los siguientes comandos:

- `chmod 640 /etc/redis/redis.conf`
- `chown redis:redis /etc/redis/redis.conf`

De esta manera, solo el usuario y grupo `redis` pueden acceder al archivo, evitando lecturas no autorizadas.

4. Cronjob con permisos incorrectos

Aquí se está señalando que los archivos o directorios relacionados con tareas programadas (cron) tienen permisos que podrían permitir que usuarios no autorizados los lean o modifiquen.

Primero vamos a ver cuáles son los permisos con el siguiente comando:

Muestra los permisos de cada directorio importante de cron

- `ls -ld /etc/cron* /var/spool/cron`

Si bien es similar al comando anterior, muestra el contenido dentro de cada directorio

- `ls -l /etc/cron*/*`

Ahora vamos a modificar estos directorios para que solo puedan ser leídos por los demás y no modificados (salvo por el root)

- `chmod 600 /etc/crontab`
- `chown root:root /etc/crontab`
- `chmod 755 /etc/cron.d /etc/cron.daily /etc/cron.hourly /etc/cron.weekly /etc/cron.monthly`
- `chown -R root:root /etc/cron*`
- `chmod 1730 /var/spool/cron`
- `chown root:crontab /var/spool/cron`
- `echo "root" > /etc/cron.allow`
- `chmod 600 /etc/cron.allow`
- `chown root:root /etc/cron.allow`

salida:

```
drwxrwxrwx 1 root root 4096 Oct 31 20:14 /etc/cron.d
drwxrwxrwx 1 root root 4096 Oct 31 20:14 /etc/cron.daily
drwxrwxrwx 1 root root 4096 Oct 31 20:14 /etc/cron.hourly
drwxrwxrwx 1 root root 4096 Oct 31 20:14 /etc/cron.monthly
drwxrwxrwx 1 root root 4096 Oct 31 20:14 /etc/cron.weekly
```

```
-rwxrwxrwx 1 root root 1580 Oct 31 21:35 /etc/crontab
drwxr-xr-x 3 root root 4096 Oct 31 20:13 /var/spool/cron
```

```
root@linux-target:/# ls -ld /etc/cron*/*
```

salida:

```
-rw-r--r-- 1 root root 201 Jan 8 2022 /etc/cron.d/e2scrub_all
-rwxr-xr-x 1 root root 1478 Apr 8 2022 /etc/cron.daily/apt-compat
-rwxr-xr-x 1 root root 123 Dec 5 2021 /etc/cron.daily/dpkg
-rwxr-xr-x 1 root root 377 May 25 2022 /etc/cron.daily/logrotate
```

[+] Scheduled tasks

- Checking crontab and cronjob files

[DONE]

Estas medidas limitan la lectura y modificación a root, evitando alteraciones no autorizadas en las tareas programadas.

5. Sudoers permisos incorrectos

Este warning indica que los archivo `/etc/sudoers` y `/etc/sudoers.d/` tiene permisos incorrectos. Esto puede causar que sudo deje de funcionar correctamente, provocar accesos no autorizados o que un usuario malintencionado modifique la configuración de sudo. Vamos a corregir los permisos con los siguientes comandos:

- `chmod 440 /etc/sudoers`
- `chown root:root /etc/sudoers`
- `chmod 750 /etc/sudoers.d`
- `chown root:root /etc/sudoers.d`

```
- Sudoers file(s) [ FOUND ]
- Permissions for directory: /etc/sudoers.d [ OK ]
- Permissions for: /etc/sudoers [ OK ]
- Permissions for: /etc/sudoers.d/README [ OK ]
```

6. Errores en la configuración de Postfix

Ese warning significa que Lynis detectó problemas en la configuración de Postfix, aunque no da un detalle exacto del error. Para saber que es lo que esta mal configurado ejecutamos el siguiente comando:

- `cat /etc/postfix/main.cf`

Problemas detectados:

- Parámetros duplicados: `inet_interfaces`, `disable_vrfy_command`, `smtpd_helo_required`, `smtpd_banner`.

- `disable_vrfy_command = no`: expone usuarios válidos del sistema.
- `smtpd_helo_required = no`: permite conexiones sin identificación (HELO/EHLO).
- Certificados autofirmados (`ssl-cert-snakeoil.pem` y `.key`).
- `myhostname = localhost`: no se recomienda; debería usarse el FQDN real.

Para solucionar estos problemas se corrigieron los duplicados y se configuraron los parametros seguros

```
bash -c 'cat > /etc/postfix/main.cf << EOF
myhostname = mail.midominio.com
smtpd_tls_cert_file=/etc/letsencrypt/live/mail.midominio.com/fullchain.pem
smtpd_tls_key_file=/etc/letsencrypt/live/mail.midominio.com/privkey.pem
smtpd_tls_security_level=may
smtp_tls_CApath=/etc/ssl/certs
smtp_tls_security_level=may
smtpd_relay_restrictions = permit_mynetworks permit_sasl_authenticated
defer_unauth_destination
mynetworks = 127.0.0.0/8 [::1]/128
alias_maps = hash:/etc/aliases
alias_database = hash:/etc/aliases
disable_vrfy_command = yes
smtpd_banner = $myhostname ESMTP
inet_interfaces = all
inet_protocols = all
EOF'
```

salida:

```
root@linux-target:/# cat /etc/postfix/main.cf
# See /usr/share/postfix/main.cf.dist for a commented, more complete version
```

```
# Debian specific: Specifying a file name will cause the first
# line of that file to be used as the name. The Debian default
# is /etc/mailname.
#myorigin = /etc/mailname
```

```
smtpd_banner = $myhostname ESMTP $mail_name (Ubuntu)
biff = no
```

```
# appending .domain is the MUA's job.
append_dot_mydomain = no
```

```
# Uncomment the next line to generate "delayed mail" warnings
#delay_warning_time = 4h

readme_directory = no

# See http://www.postfix.org/COMPATIBILITY_README.html -- default to 3.6 on
# fresh installs.
compatibility_level = 3.6
```

[+] **Software: e-mail and messaging**

```
- Postfix status [ RUNNING ]
- Postfix configuration [ FOUND ]
```

7. No hay servicio de Logs corriendo

Este warning indica que no tenemos un servicio de logs corriendo en el sistema. Esto es crítico porque si no tenemos un demonio de logs activo no se registran eventos del sistema, errores o intentos de acceso y de esta manera se dificulta detectar instrucciones o problemas.

Dentro de los demonios de login más utilizados están Rsyslog, Syslog-ng y system-journald, vamos a verificar cual están instalados con los siguientes comandos

- `dpkg -l | grep rsyslog`
- `dpkg -l | grep syslog-ng`
- `dpkg -l | grep systemd-journald`

Solo rsyslog se encontraba instalado. Comprobamos su estado:

- `ps aux | grep rsyslog`

Esto confirma que el servicio no esta corriendo así que lo ejecutamos manualmente con el siguiente comando:

- `/usr/sbin/rsyslogd`

Este comando resolvió el warning y restableció el registro de eventos del sistema.

[+] **Logging and files**

```
- Checking for a running log daemon
[ OK ]
```

8. Directorios home no tienen al usuario correcto como propietario

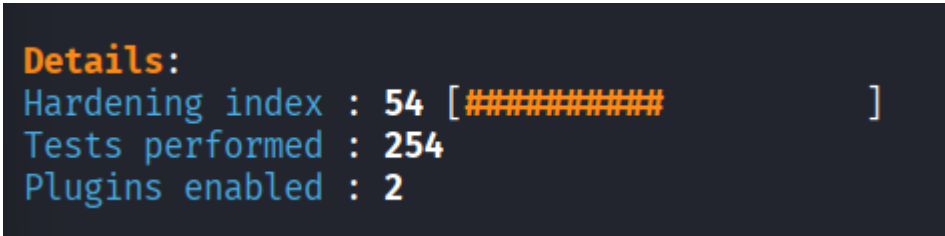
Este warning se soluciono con los siguientes comandos, ya que estos incluyen la corrección del ownership

- `chown root:root /etc/sudoers`
- `chown redis:redis /etc/redis/redis.conf`

Ahora continuamos con el hardening del sistema operativo

Configuramos de expiración y políticas en /etc/login.defs

```
cp /etc/login.defs /etc/login.defs.bak      #Crea una copia de seguridad del archivo
original antes de modificarlo
sed -i '/^PASS_MAX_DAYS/ d' /etc/login.defs  #Elimina cualquier línea existente
que defina el máximo de días que dura una contraseña
sed -i '/^PASS_MIN_DAYS/ d' /etc/login.defs  #Elimina la línea que define el
mínimo de días entre cambios de contraseña
sed -i '/^PASS_WARN_AGE/ d' /etc/login.defs  #Elimina la línea que define con
cuántos días de anticipación se avisa al usuario del vencimiento
echo "PASS_MAX_DAYS 90" | tee -a /etc/login.defs #Agrega que la contraseña
caduca cada 90 días
echo "PASS_MIN_DAYS 7" | tee -a /etc/login.defs #Agrega que el usuario debe
esperar al menos 7 días antes de cambiar su contraseña
echo "PASS_WARN_AGE 7" | tee -a /etc/login.defs #Agrega que el sistema avisa
7 días antes de que la contraseña expire
sed -i '/^UMASK/ d' /etc/login.defs          #Elimina cualquier línea anterior que defina
la umask
echo "UMASK 027" | tee -a /etc/login.defs     #Define una umask más restrictiva
(archivos nuevos con permisos 750/640 por defecto)
grep -E 'PASS_MAX_DAYS|PASS_MIN_DAYS|PASS_WARN_AGE|UMASK'
/etc/login.defs                               #Verifica que las líneas se agregaron correctamente
```



```
Details:
Hardening index : 54 [ ##### ]
Tests performed : 254
Plugins enabled : 2
```

SSH Hardeing

```
cp /etc/ssh/sshd_config /etc/ssh/sshd_config.bak      # Crea copia de respaldo
del archivo de configuración SSH
```

```

sed -i 's/^#?PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config #
Prohíbe el inicio de sesión directo como root
sed -i 's/^#?PermitEmptyPasswords.*/PermitEmptyPasswords no'
/etc/ssh/sshd_config # Bloquea logins con contraseñas vacías
sed -i 's/^#?PasswordAuthentication.*/PasswordAuthentication yes/'
/etc/ssh/sshd_config # Permite autenticación por contraseña (opcional si no se usa
clave pública)
sed -i 's/^#?MaxAuthTries.*/MaxAuthTries 3/' /etc/ssh/sshd_config # Limita a 3
intentos fallidos por conexión
sed -i 's/^#?MaxSessions.*/MaxSessions 2/' /etc/ssh/sshd_config # Permite solo 2
sesiones simultáneas por usuario
sed -i 's/^#?AllowTcpForwarding.*/AllowTcpForwarding no/' /etc/ssh/sshd_config #
Desactiva reenvío de puertos TCP (evita túneles maliciosos)
sed -i 's/^#?PermitTunnel.*/PermitTunnel no/' /etc/ssh/sshd_config # Desactiva
túneles de red a través de SSH
sed -i 's/^#?AllowAgentForwarding.*/AllowAgentForwarding no/'
/etc/ssh/sshd_config # Evita reenvío del agente SSH (protege claves locales)
sed -i 's/^#?GatewayPorts.*/GatewayPorts no/' /etc/ssh/sshd_config # Bloquea
que SSH escuche en direcciones externas
sed -i 's/^#?LogLevel.*/LogLevel VERBOSE/' /etc/ssh/sshd_config # Aumenta el
nivel de detalle en los registros SSH
sed -i 's/^#?ClientAliveCountMax.*/ClientAliveCountMax 2/' /etc/ssh/sshd_config #
Finaliza sesiones inactivas tras 2 mensajes sin respuesta
sed -i 's/^#?X11Forwarding.*/X11Forwarding no/' /etc/ssh/sshd_config #
Desactiva reenvío gráfico X11 (riesgo de fuga de datos)
sed -i 's/^#?StrictModes.*/StrictModes yes/' /etc/ssh/sshd_config # Obliga
permisos correctos en archivos y directorios del usuario
systemctl restart sshd || service ssh restart # Reinicia el servicio SSH para
aplicar los cambios
sshd -T | grep -E
'permitrootlogin|maxauthtries|allowtcpforwarding|loglevel|x11forwarding' # Verifica
que los parámetros estén activos

```

Details:

```

Hardening index : 65 [#####]
Tests performed : 254
Plugins enabled : 2

```

Kernel Hardening

Para esto debemos crear o sobrescribir el archivo con parámetros de seguridad del kernel

```
tee /etc/sysctl.d/99-hardening.conf > /dev/null <<'EOF'
```

```

kernel.randomize_va_space = 2 # Activa la aleatorización de direcciones de memoria
kernel.kptr_restrict = 2      # Restringe la lectura de direcciones del kernel
kernel.dmesg_restrict = 1     # Restringe acceso a los mensajes del kernel
kernel.sysrq = 0              # Desactiva combinaciones SysRq (previene abuso del teclado
                               en consola)
kernel.yama.ptrace_scope = 2  # Limita el uso de ptrace (bloquea debugging de
                               procesos ajenos)
kernel.unprivileged_bpf_disabled = 1 # Desactiva el uso de BPF por usuarios sin
                               privilegios (reduce superficie de ataque)
fs.protected_fifos = 2        # Protege pipes y FIFOs frente a accesos no autorizados
dev.tty.ldisc_autoload = 0     # Evita carga automática de módulos de línea TTY
net.ipv4.conf.all.accept_redirects = 0 # Bloquea redirecciones ICMP
net.ipv4.conf.default.accept_redirects = 0 # Idem para interfaces nuevas
net.ipv4.conf.all.send_redirects = 0    # Evita enviar redirecciones ICMP
net.ipv4.conf.all.rp_filter = 1          # Activa filtrado de rutas falsas
net.ipv4.conf.all.log_martians = 1       # Registra paquetes con IPs sospechosas
net.ipv4.conf.default.log_martians = 1   # Aplica también a interfaces nuevas
net.ipv6.conf.all.accept_redirects = 0    # Bloquea redirecciones ICMPv6
net.ipv6.conf.default.accept_redirects = 0 # Aplica también a interfaces nuevas
IPv6
EOF
sysctl --system # Aplica los parámetros de todos los archivos /etc/sysctl.d/ sin
reiniciar el sistema

```

```

Details:
Hardening index : 66 [#####]
Tests performed : 254
Plugins enabled : 2

```

Instalar Malware scanners / rootkit checkers

```

apt install -y rkhunter chkrootkit # Instala las herramientas Rkhunter y Chkrootkit
para detectar rootkits, puertas traseras y malware en el sistema
rkhunter --update # Actualiza la base de datos de firmas y configuraciones que
usa Rkhunter para sus análisis
rkhunter --check --skip-keypress # Ejecuta un escaneo completo del sistema con
Rkhunter buscando rootkits, archivos alterados o comportamientos sospechosos
chkrootkit # Ejecuta Chkrootkit para detectar de forma rápida rootkits conocidos y
rastros de infecciones en el sistema

```

Lynis modules:

- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Details:

Hardening index : 67 [#####]
Tests performed : 256
Plugins enabled : 2

Al final de todo el proceso de hardening obtenemos los siguientes resultados

¿Qué Hardening index obtuvo? 67

¿Cuántos warnings? 2

¿Cuántas sugerencias? 43

(adjunto archivo: salida-lynis post.txt)

Tenga en cuenta de que no se puede apagar el firewall y que debe existir una regla que bloquee las conexiones entrantes de telnet, compruebe que esto sea así, caso contrario cree la regla y fíjese si lynis la marca como solución. ¿Por qué ocurre eso? ¿A algún otro de los warning le pasa lo mismo? ¿Se pueden arreglar todas las sugerencias?

En la configuración actual del firewall, la política por defecto de la cadena INPUT esta establecida en DROP, lo que implica que cualquier conexión entrante que no coincida con una regla explicita sera descartada. Dado que no se incluyo una regla que permita el puerto 23/tcp (telnet) este servicio queda implícitamente bloqueado. De todas formas Lynis recomienda tener de manera explicita una regla que bloquee telnet y por ende marca igualmente la ausencia de una regla dedicada porque considera que los servicios obsoletos deben estar protegidos mediante controles visibles y específicos

No todas las recomendaciones de Lynis pueden o deben aplicarse, algunas son informativas, otras dependen del caso de uso del sistema y otras pueden entrar en conflicto con servicios legítimos. El objetivo del análisis no es alcanzar un puntaje perfecto, sino justificar razonadamente qué controles se aplican y por qué.

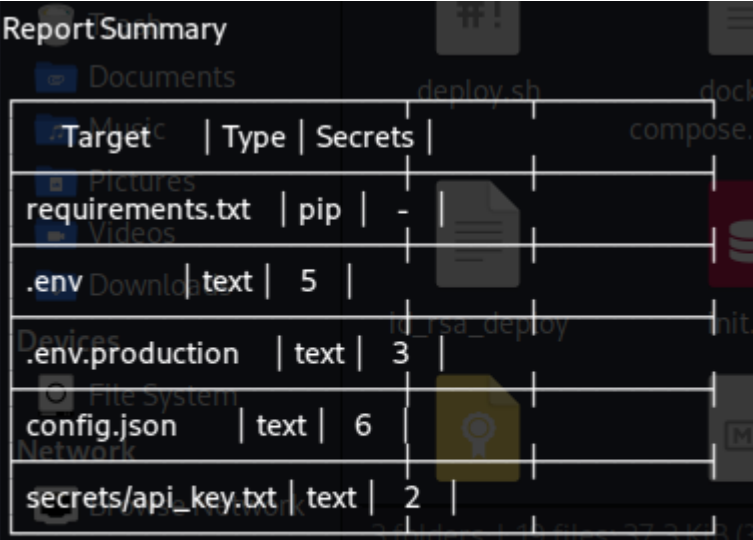
Parte 2 - Analizadores de código estático

Secrets en el código

¿Cuál encontró más secretos? ¿Cuál le parece que es mejor? Justifique.

Comando para la ejecución de Trivy:

- `docker run --rm -v $(pwd):/project aquasec/trivy fs --security-checks secret /project`



Report Summary

Target	Type	Secrets
requirements.txt	pip	-
.env	text	5
.env.production	text	3
config.json	text	6
secrets/api_key.txt	text	2

Legend: -
- '-': Not scanned
- '0': Clean (no security findings detected)

(adjunto archivo: trivy_scan.txt)

Comando para la ejecución de Trufflehog:

- `docker run --rm -v $(pwd):/project trufflesecurity/trufflehog filesystem /project`

```
2025-11-13T14:19:02Z info-0 trufflehog finished scanning {"chunks": 75, "bytes": 113247, "verified_secrets": 0, "unverified_secrets": 24, "scan_duration": "6.1627325s", "trufflehog_version": "3.91.0", "verification_caching": {"Hits": 39, "Misses": 59, "HitsWasted": 4, "AttemptsSaved": 35, "VerificationTimeSpentMS": 75896}}
```

(adjunto archivo: trufflehog_scan.txt)

En un sentido literal, Trufflehog encontró más secretos que Trivy, 24 no verificados frente a 16. Trufflehog reportó 24 “unverified secrets” lo que significa que detectó posibles claves o tokens en el código y los archivos, aunque no logró verificar su validez mediante las API correspondientes. Esto indica potenciales puntos de exposición o malas prácticas, como almacenar credenciales en texto plano, aunque no necesariamente compromisos reales.

Por su parte, Trivy se limita a detectar patrones conocidos dentro de archivos (por ejemplo, .env, .json, .yaml, .config, etc), pero no intenta probar si esas claves funcionan, ni si estan vigentes o si pertenecen a algún servicio real.

Para determinar cual es mejor hay que considerar el contexto.

Trufflehog se utiliza principalmente para detectar la exposición de secretos dentro del código fuente o del historial de commits de un repositorio. Es especialmente útil durante auditorías de seguridad o antes de publicar un proyecto en repositorios públicos, ya que permite identificar credenciales, tokens o contraseñas que podrían haber quedado visibles en el código.

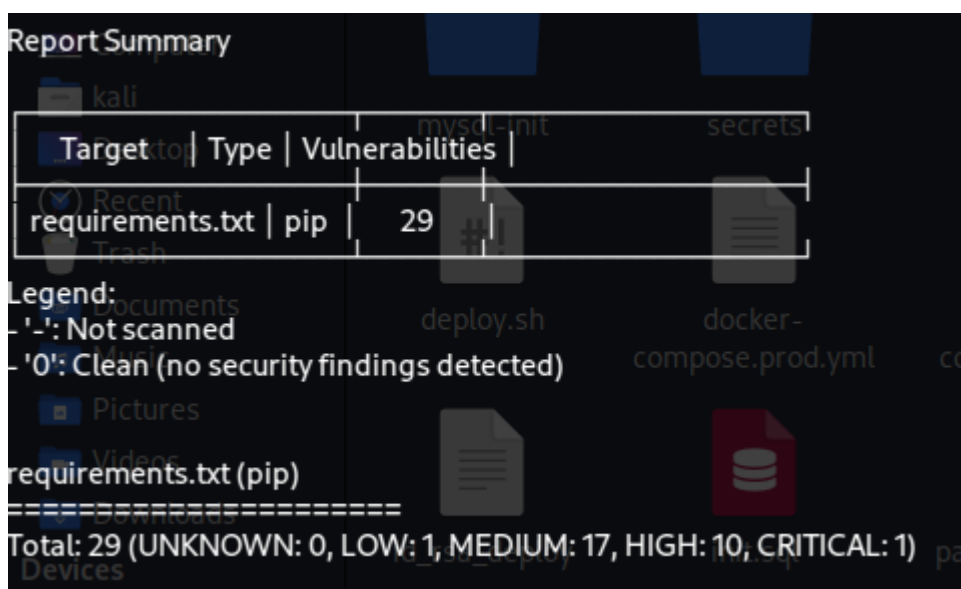
Mientras que Trivy, es una herramienta más integral y orientada al análisis de seguridad en proyecto y entornos de desarrollo. Además de buscar secretos permite detectar vulnerabilidades de dependencias, analiza configuraciones inseguras y evalúa la seguridad de contenedores Docker o archivos de infraestructura.

Vulnerabilidades en las dependencias.

Investigue cómo utilizar Trivy para analizar vulnerabilidades en el archivo requirements.txt que está en el repositorio. Luego trate de solucionarlas y vuelva a realizar el escaneo

Para detectar vulnerabilidades en el archivo requirements.txt, utilizamos Trivy con:

- `docker run --rm -v $(pwd):/project aquasec/trivy fs --scanners vuln /project`
(adjunto archivo: salida dependencias trivy.txt)



The screenshot shows a terminal window with the Trivy report summary for requirements.txt. The report is displayed in a table format with columns for Target, Type, and Vulnerabilities. The target is requirements.txt, the type is pip, and there are 29 vulnerabilities found. A legend indicates that '!' means 'Not scanned' and '0' means 'Clean (no security findings detected)'. The total count is 29 (UNKNOWN: 0, LOW: 1, MEDIUM: 17, HIGH: 10, CRITICAL: 1).

Target	Type	Vulnerabilities
requirements.txt	pip	29

Legend:
- '!': Not scanned
- '0': Clean (no security findings detected)

requirements.txt (pip)

Total: 29 (UNKNOWN: 0, LOW: 1, MEDIUM: 17, HIGH: 10, CRITICAL: 1)

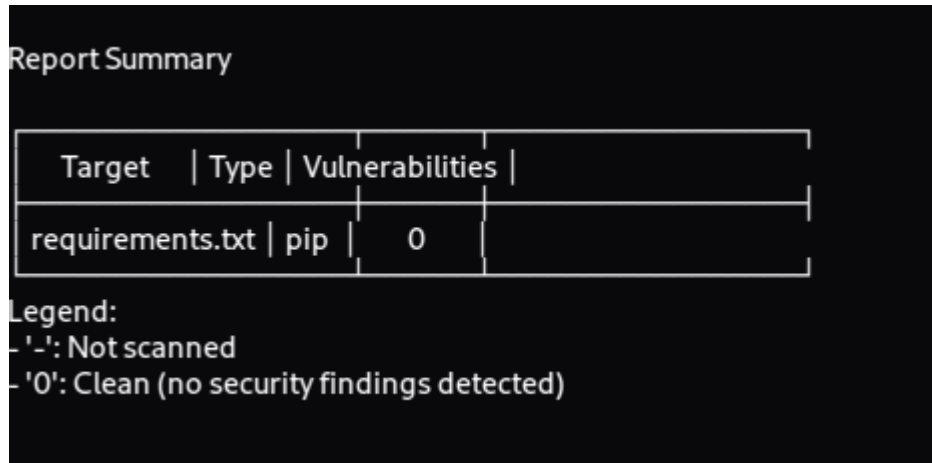
Trivy analiza las dependencias listadas y reporta las vulnerabilidades conocidas. Con base en esta información, se identifican las dependencias que necesitan ser actualizadas y se modifican sus versiones a versiones seguras y estables en

requirements.txt.

Finalmente, se instalan las dependencias actualizadas con:

- `pip install -r requirements.txt --upgrade`

Tras esta actualización, volvemos a ejecutar Trivy para confirmar que las vulnerabilidades detectadas anteriormente han sido mitigadas.



Report Summary

Target	Type	Vulnerabilities
requirements.txt	pip	0

Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)

Desarrolle los conceptos de mayor, minor y bug fix y explique porque no siempre es posible actualizar a la última versión.

Los términos de mayor, minor y bug fix pertenecen al versionado semántico, un estándar ampliamente difundido en dependencias de software. Su nomenclatura es la siguiente: Major.Minor.BugFix

Mayor: Hace referencia a un cambio mayor; se incrementa cuando hay cambios incompatibles con versiones anteriores. Puede eliminar funciones, modificar APIs o alterar el comportamiento esperado. Requiere que el desarrollador adapte el código para poder utilizar esta versión.

Ejemplo: 2.0.0 a 3.0.0

Minor: referencia a nuevas funcionalidades, se incrementa cuando se agregan funcionalidades nuevas, pero manteniendo compatibilidad con versiones mayores previas. Este tipo de actualizaciones no debería afectar al software ya realizado

Ejemplo: 2.3.0 a 2.4.0

Patch (o Bug Fix): se incrementa para corregir bugs, problemas menores o vulnerabilidades. No agrega funcionalidades nuevas y es siempre compatible dentro de la versión mayor.

Ejemplo: 2.3.0 a 2.3.1

¿Por qué no siempre es posible actualizar a la última versión?

Aunque siempre actualizar dependencias es deseable por motivos de seguridad, no siempre puede ser viable hacerlo, especialmente cuando se trata de pasar a la última versión disponible.

Uno de los principales motivos es que una actualización mayor puede introducir cambios incompatibles que rompan la aplicación, eliminen funciones utilizadas o requieran reescribir partes de tu código para adaptarlo.

Además, actualizar una dependencia puede afectar a otras dependencias que la integraba en su funcionamiento, generando conflictos de compatibilidad entre ellas.

En otros casos, la última versión puede requerir una versión más reciente del lenguaje del sistema operativo o del framework, lo cual puede no ser posible dependiendo del entorno actual. También puede ocurrir que la aplicación dependa de un comportamiento no documentado, y que la nueva versión lo modifique por ende ocasionando fallos inesperados.

Hardening

Investigue cómo utilizar Trivy para analizar un Dockerfile, utilícelo en el Dockerfile que hay en el repositorio, si encuentra cosas que no estén bien configuradas modificarlo hasta que no se encuentre nada

Trivy mediante el parámetro config activa el escaneo de configuraciones (misconfigurations), que incluye la revisión del Dockerfile.

En este modo Trivy detecta problemas como:

- uso del usuario root
- imágenes base sin versionar
- comandos inseguros
- paquetes instalados sin actualización
- permisos inseguros

Este análisis no busca vulnerabilidades en dependencias, sino errores de configuración y malas prácticas de hardening dentro del Dockerfile.

Este es el comando necesario para realizar el análisis:

- `docker run --rm -v $(pwd):/project aquasec/trivy config /project`

Target	Type	Misconfigurations
Dockerfile	dockerfile	11

(adjunto archivo: missconfiguration dockerfile.txt)

Tras la corrección del Dockerfile volvemos a ejecutar el análisis.

Report Summary		
"Dockerfile" 743 bytes Plain text document		
Target	Type	Misconfigurations
Dockerfile	dockerfile	0

Parte 3 - "Pentesting" de un ejecutable

Describir qué hace el programa, ya sea vía la ejecución del archivo o analizando el código fuente. Ignore los mensajes sobre la VPN y la autenticación, tampoco es muy relevante saber qué es y que hace SAP.

¿Que hace el programa?

Es una herramienta de automatización para SAP GUI que permite interactuar con sistemas empresariales SAP de forma automática. El programa lee un archivo CSV desde una ruta fija, extrae una lista de códigos de transacción y los ejecuta en SAP GUI utilizando pyautogui.

Además, la herramienta realiza capturas de pantalla periódicas, detecta y reporta errores durante la ejecución, permite la interacción con el usuario a través de la consola y registra toda la actividad en un archivo de log.

Encontrar vulnerabilidades en el ejecutable, que afecten a la máquina donde se está ejecutando y aunque no lo podamos demostrar al servidor.

Utilizando el documento: Informe pentest realizar un informe que documente los hallazgos encontrados.

Hallazgo 1: Automatización de coordenadas sin validación

Severidad	Crítico	CVSS	9.4 - CVSS:4.0/AV:L/AC:L/AT:N/PR:N /UI:N/VC:H/VI:H/VA:H/SC:H/SI: H/SA:H
Descripción	El ejecutable automatiza SAP GUI mediante pyautogui, controlado el cursor del mouse y el teclado utilizando coordenadas absolutas de pantalla. No se verifica si SAP GUI esta en primer plano, si la ventana a manipular es la correcta, si hubo cambios en la resolución, si existe algún popup, si el usuario movió el mouse o si apareció otra aplicación interceptando la entrada. Como resultado, cualquier pequeña alteración del entorno puede provocar que el script haga clic en aplicaciones del sistema o escritorio, escribir texto o comandos en ventanas no previstas, ejecute accesos directos del sistema, modifique, borre o abra archivo		
CWE	CWE-1021 CWE-20 CWE-668	Stride	Elevation of Privilege
Impacto	El impacto es critico debido a que el script puede ejecutar acciones imprevistas, como por ejemplo: borrado accidental de archivos, cambio de configuraciones del sistema, apertura de aplicaciones, ejecución de comandos involuntarios o tambien la ejecución de transacciones SAP no autorizadas, carga o modificación de datos sensibles y la posible corrupción de datos por operación fuera de contexto.		
Referencias	https://cwe.mitre.org/data/definitions/1021.html https://cwe.mitre.org/data/definitions/20.html https://cwe.mitre.org/data/definitions/668.html		
Prueba de concepto			
1. Ejecutar el script. 2. Durante la automatización, abrir una ventana (ej: Bloc de Notas). 3. Como consecuencia, se observa que: a. El script escribe texto en la ventana equivocada. b. Puede cerrar programas, abrir archivos o ejecutar acciones no deseadas.			
Adjunto video de prueba			

<https://www.youtube.com/watch?v=aXYSB19o9gs>

Recomendaciones

1. Eliminar por completo la automatización basada en pyautogui. No es segura ni apropiada para entornos SAP.
2. Utilizar SAP GUI Scripting oficial, que ofrece: objetos estructurados, validación de campos, determinación correcta de la ventana activa, interacción sin coordenadas.
3. Implementar validaciones estrictas: verificar que SAP GUI está en primer plano, comprobar que la transacción es la correcta, confirmar ubicaciones de los campos, detener la ejecución ante popups inesperados.
4. Controlar errores y detener la automatización si el entorno cambia.
5. Evitar automatizar acciones críticas por teclado/mouse y usar APIs o scripting autorizados siempre que sea posible.

Hallazgo 2: Exposición de rutas sensibles en mensajes de consola

Severidad	Media	CVSS	4.8 - CVSS:4.0/AV:L/AC:L/AT:N/PR :L/UI:N/VC:L/VI:N/VA:N/SC:N /SI:N/SA:N
Descripción	El ejecutable imprime rutas internas del sistema y archivos utilizados durante la automatización. En entornos corporativos, esta práctica revela información sensible sobre la estructura interna del sistema.		
CWE	CWE - 200	Stride	Information Disclosure
Impacto	● Permite a un atacante mapear la estructura interna de directorios. ● Expone rutas completas a ejecutables, CSV de entrada y archivos temporales. ● Facilita la búsqueda y explotación de otros vectores (manipulación de archivos, ejecución no autorizada, elevación de privilegios). ● Aumenta la superficie de ataque al revelar la ubicación exacta de recursos críticos.		
Referencias	https://cwe.mitre.org/data/definitions/200.html		
Prueba de concepto			

Al ejecutar el script, la consola muestra rutas absolutas utilizadas en el proceso (por ejemplo, la ruta del archivo transacciones.csv y las carpetas donde se almacenan logs y capturas).

```
Verificando/Creando estructura inicial...
Configuración inicial...
Carpeta C:\Volar\python ya existe.
Carpeta C:\Volar\python\input ya existe.
Carpeta C:\Volar\python\capturas_sap_test ya existe.
CSV C:\Volar\python\input\transacciones.csv ya existe.
Configuración inicial OK.
```

Recomendaciones

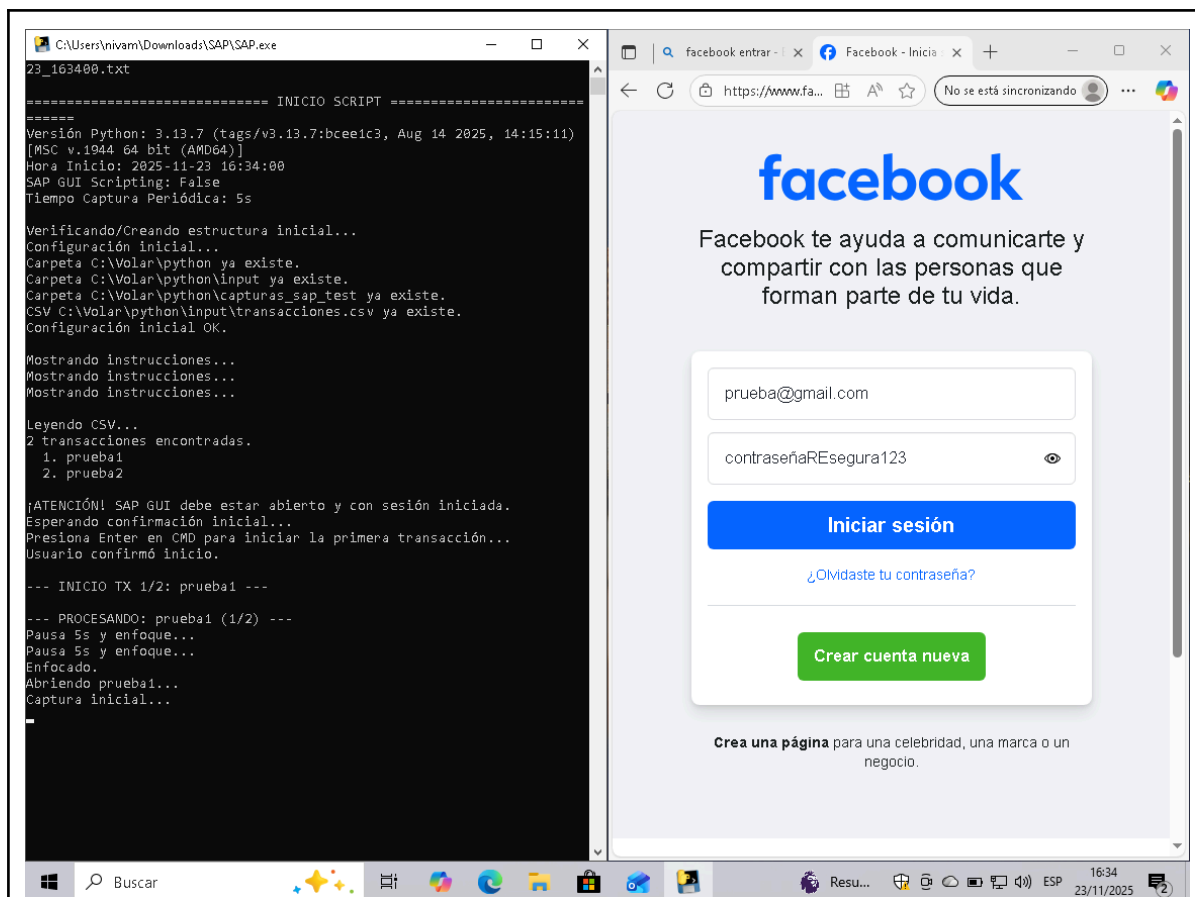
- Evitar imprimir rutas completas en consola o logs por defecto.
- Utilizar mensajes abstractos (“Archivo generado correctamente”, “Transacción cargada”).
- Implementar niveles de logging configurables (INFO/DEBUG/ERROR), manteniendo la información sensible solo en DEBUG.

Hallazgo 3: Capturas de pantalla arbitrarias rompen confidencialidad

Severidad	Media	CVSS	6.8 - CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N
Descripción	El proceso automatizado genera capturas de pantalla durante la ejecución sin control sobre su contenido, momento de captura o contexto visual. Esta funcionalidad no implementa ningún tipo de restricción respecto a: • qué ventanas se encuentran abiertas, • qué aplicaciones están en primer plano, • si se muestran credenciales, datos personales o información sensible, • si los screenshots contienen otras aplicaciones corporativas o privadas ajenas al proceso de SAP. Como resultado, el mecanismo de captura opera de forma arbitraria y puede almacenar imágenes que expongan información confidencial del usuario o de la organización. Esto constituye una fuga de información inadvertida (unintentional information disclosure), especialmente crítica en entornos corporativos donde múltiples aplicaciones sensibles pueden estar abiertas simultáneamente (correo, VPNs, sistemas internos, tokens, chats, documentación interna, etc.).		

CWE	CWE - 200	Stride	Information Disclosure
Impacto	- Exposición involuntaria de credenciales, tokens, mensajes privados o información corporativa. - Fuga de datos sensibles visibles en el escritorio o ventanas activas. - Riesgo de filtración de información confidencial si los screenshots se guardan en ubicaciones accesibles por terceros. - Posibilidad de correlación temporal (timestamp → actividad del usuario) útil para atacantes internos. - Incremento de superficie de ataque al almacenar imágenes con información operativa o arquitectónica.		
Referencias	https://cwe.mitre.org/data/definitions/200.html		
Prueba de concepto			
- Ejecutar el script mientras: - Se tienen abiertas aplicaciones como Outlook, SAP GUI, navegadores, VPN, mensajería o sistemas internos. - Observar que el script genera capturas sin verificar el estado del escritorio. - Revisar la carpeta de salida (donde se almacenen) y confirmar que: - se almacenan imágenes con información visible en otras aplicaciones, - la ruta es accesible por otros usuarios,			

La siguiente captura forma parte de las tomadas por el script durante su ejecución



Recomendaciones

- Implementar capturas solo del área de la ventana objetivo mediante API dedicadas, evitando el escritorio completo.
- Validar contexto antes de capturar.
- Enmascarar o blackout automático de áreas sensibles dentro de la imagen.
- Cifrar las capturas en reposo o almacenarlas en rutas controladas con permisos restrictivos.
- Deshabilitar las capturas por defecto y activarlas únicamente en modo DEBUG.
- Implementar un banner de advertencia para el usuario antes de iniciar la automatización.
- Evitar capturas aleatorias y reemplazarlas por logs estructurados cuando sea posible.

Parte 4 - Analisis y reflexion sobre normativas

Identificar y seleccionar diez artículos del GDPR que consideren directamente relevantes para el abordaje y la gestión de la ciberseguridad en una organización

Artículos seleccionados:

1. Art. 5 - Principios relacionados al tratamiento de datos personales
2. Art. 6 - Legalidad del tratamiento
3. Art. 9 - Tratamiento de categorías especiales de datos personales
4. Art. 25 - Protección de datos desde el diseño y por defecto
5. Art. 28 - Encargado del tratamiento
6. Art. 30 - Registro de actividades de tratamiento.
7. Art. 32 - Seguridad del procesamiento
8. Art. 33 - Notificación de una violación de la seguridad de los datos personales a la autoridad de control
9. Art. 35 - Evaluación de Impacto de la protección de datos
10. Art 39 - Funciones del delegado de protección de datos

Deberán argumentar detalladamente la elección de cada artículo, explicando cómo su cumplimiento impacta o moldea las políticas y prácticas de seguridad de la información (ej., en relación con el cifrado, el manejo de incidentes o el diseño de sistemas).

Artículo 5 - Principios del tratamiento

Este artículo establece los principios fundamentales que gobiernan todo tratamiento de datos: integridad, confidencialidad, minimización, limitación del acceso y responsabilidad. Estos conceptos se aplican como un pilar ético y técnico, ya que obligan a las organizaciones a implementar controles que garanticen que los datos no serán manipulados, divulgados o accedidos de forma ilegítima. Además estos principios sirven como marco guía para controles como cifrado, clasificación de datos y monitoreo de actividades.

Artículo 6 - Legalidad del tratamiento

Este artículo establece la base jurídica para el tratamiento de datos por parte de la organización, esta debe asegurar que sólo sujetos autorizados accedan y manipulen los datos. Esto se traduce en prácticas de ciberseguridad como gestión estricta de identidades y autenticación fuerte, manejo de acceso, segregación de funciones y el cifrado. Si un tratamiento no tiene base legal cualquier acceso sería equivalente a una brecha.

Artículo 9 - Datos sensibles

Al tratarse de datos altamente sensibles (salud, biométricos, etc), el nivel de seguridad que debe implementarse sobre los mismos aumenta. Las organizaciones deben establecer medidas reforzadas como un cifrado avanzado, pseudonimización, segmentación de redes, monitoreo continuo y mayores restricciones de acceso. Además se exige un análisis más meticuloso sobre riesgos más profundos para justificar el tratamiento seguro de este tipo de información.

Artículo 25 - Protección por diseño

Este artículo integra la seguridad como parte obligatoria del ciclo de vida del software y sistemas. Obliga a las organizaciones a aplicar medidas como: cifrado nativo, gestión segura de entidades, configuraciones seguras por defecto y minimización automática de datos.

De esta forma se moldean prácticas como el desarrollo seguro (DevSecOps), pruebas obligatorias, revisiones de arquitectura y uso de patrones de diseño orientados a la protección de datos.

Artículo 28 - Encargado del tratamiento

En este artículo se regula la seguridad en proveedores de servicios, tales como plataformas Cloud o SaaS. Obliga a formalizar contratos que garanticen medidas técnicas y organizativas adecuadas, auditorías, confidencialidad y notificación de incidentes. En la práctica, obliga a la organización a tener procesos de: evaluación de proveedores, cláusulas contractuales de seguridad, auditorías de terceros y exigencias como el cifrado, la continuidad de negocio y controles de acceso.

Este artículo provee un abordaje a una de las áreas más críticas de una organización: la seguridad en la cadena de suministro

Artículo 30 - Registro de actividades

El registro de actividades funciona como base para auditorías, análisis de riesgos y diseño de controles. Permite identificar flujos sensibles, puntos de entrada, dependencias y sistemas críticos. A nivel de ciberseguridad se alimenta el inventario de activos, los modelos de amenazas, las políticas de acceso, la clasificación de información y la definición de controles basados en riesgo.

Sin saber qué datos se procesan, cómo, con qué fin y en qué sistemas, resulta imposible definir controles de seguridad adecuados.

Artículo 32 - Seguridad del procesamiento

Este es el núcleo técnico del GDPR. El artículo exige:

- Cifrado y pseudonimización
- Asegurar la confidencialidad, integridad y disponibilidad

- Capacidad de restauración tras incidentes (resiliencia)
- Evaluación periódica de la eficacia de medidas técnicas

A partir de esto, se derivan políticas como: políticas de cifrado, planes de continuidad del negocio, controles de accesos y autenticación multifactor, hardening de sistemas y pruebas de seguridad (pentesting, auditorías, escaneo de vulnerabilidades, etc)

Este artículo es el enlace más claro entre el GDPR y los estándares de ciberseguridad (ISO 27001, NIST, CIS).

Artículo 33 - Notificación de brechas

Este artículo obliga a desarrollar un sistema estructurado, documentado y rápido de gestión de incidentes que permita detectar, analizar, responder y notificar en menos de 72 horas. Esto implica:

- Sistemas de monitoreo y detección de intrusiones (IDS/IPS) para identificar y bloquear comportamiento sospechoso en redes.
- Plataformas SIEM para registrar, centralizar y correlacionar eventos de seguridad (por ejemplo Wazuh).
- Procedimientos internos de respuesta con roles definidos, tiempos de respuesta y acciones claras.
- Playbooks de incidente que permitan guiar la actuación frente a distintos tipos de incidentes.
- Entrenamiento de equipos de seguridad para garantizar que las acciones sean rápidas, coordinadas y conforme a la normativa.
- Políticas de comunicación y escalamiento para informar correctamente a superiores, responsables legales y, en caso que sea necesario, a los afectados.

Además, exige documentar de forma completa cada brecha: qué ocurrió, qué datos fueron afectados, cuál fue el impacto, qué medidas correctivas se aplican y cómo se evitará que vuelva a ocurrir.

Artículo 35 - Evaluación de impacto de la protección de datos (DPIA)

El DPIA es una obligación para cualquier tratamiento que implique un riesgo alto para los derechos de los individuos. Su función es fundamental: obliga a integrar la gestión de riesgos antes de desplegar tecnologías o procesos nuevos. Esto incluye:

- Identificación de riesgos técnicos (vulnerabilidades, amenazas)

- Evaluación de controles existentes y mitigaciones
- Revisión de proveedores, sistemas, arquitecturas y tecnologías
- Determinación de medidas adicionales necesarias

Los DPIA convierten al desarrollo tecnológico en un proceso planificado, donde la seguridad se evalúa, justifica y documenta.

Artículo 39 - Funciones del Delegado de Protección de Datos (DPO)

Este artículo establece las funciones del DPO, quien actúa como supervisor, asesor y punto de conexión entre las áreas técnicas, legales y la autoridad de control. Esta figura se encarga de vigilar, coordinar y exige cumplimiento continuo.

Su rol impacta en:

- Concientización y formación interna del personal en la protección de datos
- Revisión de políticas, incidentes, medidas de mitigación y DPIA
- Evaluación constante de la adecuación técnica de los controles
- Supervisión del cumplimiento continuo del GDPR
- Coordinación con equipos de TI, ciberseguridad, legal y auditoría

Ayuda a convertir la ciberseguridad en un proceso continuo y no solo técnico.

Elaborar una crítica fundamentada sobre los puntos débiles o las limitaciones, que consideren del GDPR en relación con los desafíos actuales de la ciberseguridad (ej., tecnologías emergentes, big data, o la aplicación en contextos de ataque avanzado).

El GDPR posee una ambigüedad técnica y una falta de requisitos mínimos. Si bien exige “medidas técnicas y organizativas apropiadas”, uno de los más grandes problemas que posee recae en la falta de estándares técnicos mínimos ni calendarios de actuación, esto deja un margen interpretativo amplio; mientras da flexibilidad, también deja a las empresas la incertidumbre sobre que es suficiente frente a amenazas modernas.

Por eso es importante complementar el GDPR con marcos técnicos conocidos como NIST CSF, ISO 27001 y CIS.

Puntualmente, el artículo 33 del GDPR obliga a notificar una brecha de seguridad a la autoridad competente dentro de las 72 horas posteriores a su detección. En el contexto actual, esta exigencia resulta problemática frente a ataques sofisticados, como los asociados a amenazas persistentes avanzadas (APT), que pueden

permanecer ocultos durante semanas o meses, recopilando información y moviéndose silenciosamente dentro de la red. En estos escenarios, una notificación apresurada puede producir dos efectos indeseados: comunicaciones incompletas o incorrectas, debido a que la organización aún no comprende totalmente el incidente, y la exposición anticipada de información que podría permitir a los atacantes ajustar su comportamiento al observar la reacción defensiva.

Una posible mejora sería adoptar un esquema de comunicaciones progresivas, donde la organización informe primero que se ha detectado un incidente y luego, conforme avanza la investigación, actualice qué se está analizando, qué sistemas podrían estar afectados y qué medidas se están tomando. Esto reduciría la presión del plazo de 72 horas y evitaría notificaciones incompletas o basadas en información todavía incierta.

Otro problema se encuentra en el artículo 28, que establece obligaciones estrictas para garantizar que los proveedores y subprocesadores protejan adecuadamente los datos personales. En la práctica, muchos de los contratos exigidos por el GDPR terminan convirtiéndose en documentos formales con cláusulas genéricas que no siempre se traducen en controles técnicos verificables. Además, la participación de múltiples subprocesadores, e incluso sub-subprocesadores, dificulta mantener una supervisión real sobre toda la cadena de suministro. Como consecuencia, las organizaciones dependen en gran medida de la confianza en el proveedor y asumen riesgos que no siempre pueden evaluar o auditar de forma independiente.

Como medida general, estos riesgos pueden mitigarse seleccionando proveedores con certificaciones verificables, solicitando reportes independientes cuando sea posible, estableciendo requisitos claros de seguridad en los contratos y reforzando la protección mediante el uso de cifrado.

Con respecto a la evaluación de impacto previa al tratamiento (DPIA), si bien constituye una herramienta poderosa para identificar riesgos, en la práctica puede transformarse en un documento formal sin la profundidad técnica necesaria o, en el extremo contrario, en un proceso demasiado lento que obstaculiza la innovación. Esto genera dos efectos: DPIA burocráticos que retrasan despliegues críticos, o bien evaluaciones superficiales que no llegan a detectar riesgos reales.

Una forma de mitigar este problema es integrar el DPIA dentro del ciclo de desarrollo (DevSecOps), automatizar partes del proceso mediante plantillas y listas técnicas, y asegurar revisiones técnicas obligatorias como parte de la evaluación.

En el caso de los dispositivos IoT, muchos cuentan con recursos limitados y suelen carecer de mecanismos de actualización segura, almacenamiento protegido o cifrado robusto. Aunque el GDPR exige la aplicación de medidas técnicas “adecuadas”, gran parte del ecosistema IoT no permite implementar controles básicos, utiliza credenciales por defecto o directamente no soporta actualizaciones.

Esto genera un vacío técnico-normativo: la regulación exige protección, pero la propia tecnología dificulta cumplirla.

Como mitigación general, pueden aplicarse políticas de adquisición que exijan seguridad por diseño, segmentación de red para aislar estos dispositivos, uso de gateways que aporten cifrado o validación, y contratos que obliguen a mantener actualizaciones y soporte.

Por último, considero que el GDPR tiende a imponer obligaciones similares para grandes empresas y pymes. Aunque existe cierta noción de proporcionalidad, en la práctica las organizaciones pequeñas enfrentan limitaciones claras en recursos, personal técnico y capacidad de implementar medidas avanzadas de seguridad. Esto genera un desbalance donde las pymes quedan en desventaja frente a los requisitos regulatorios.